

● HIGH SEVERITY

PHISHING ATTACK

INCIDENT RESPONSE PLAYBOOK

ORGANIZATION	University of Delaware
PREPARED BY	Kavya Sri Reddy
GENERATED	2026-05-27 15:48:29
NIST FUNCTIONS	Detect, Respond, Recover
SLA — CONTAINMENT	4 hours
SLA — RESOLUTION	72 hours

INCIDENT DESCRIPTION

A social engineering attack where adversaries send fraudulent emails to trick users into revealing credentials or installing malware.

MITRE ATT&CK; TACTICS

- Initial Access (TA0001)
- Credential Access (TA0006)

INDICATORS OF COMPROMISE (IOCs)

- Sender email/domain
- Malicious URLs
- File hashes of attachments
- IP addresses in headers

ESCALATION MATRIX

SEVERITY	ESCALATION PATH
Low	SOC Tier 1 analyst
High	SOC Tier 2 + IT Security Manager
Critical	CISO + Legal + HR (if data exfiltration suspected)

PHASE: IDENTIFICATION [0–1 hour]

NIST Control: DE.AE-2 — Detected events are analyzed to understand attack targets and methods

TOOLS: Email gateway logs, VirusTotal, URLScan.io, SIEM

RESPONSE STEPS

- 1 Receive and triage phishing report from user or email gateway alert
- 2 Collect the suspicious email (headers, body, attachments, links)
- 3 Search mail logs for all recipients of the same email
- 4 Check URLs and attachments against threat intelligence (VirusTotal, URLScan)
- 5 Determine if any user clicked links or opened attachments
- 6 Assign severity: Low (no clicks), High (credentials entered), Critical (malware executed)

PHASE: CONTAINMENT [1–4 hours]

NIST Control: RS.MI-1 — Incidents are contained

TOOLS: Email admin console, Active Directory, Firewall/Proxy, EDR

RESPONSE STEPS

- 1 Block sender domain and IP at email gateway
- 2 Quarantine or delete the phishing email from all mailboxes
- 3 Reset credentials for any users who submitted passwords
- 4 Enable MFA immediately for affected accounts
- 5 Isolate any endpoint that executed an attachment
- 6 Block malicious URLs at web proxy / firewall

PHASE: ERADICATION [4–24 hours]

NIST Control: RS.MI-2 — Incidents are mitigated

TOOLS: EDR platform, Microsoft 365 Admin, AD Audit logs

RESPONSE STEPS

- 1 Remove malware from affected endpoints using EDR tooling
- 2 Audit OAuth app permissions granted during the attack window
- 3 Review forwarding rules added to compromised mailboxes
- 4 Revoke and reissue any exposed API keys or tokens
- 5 Conduct full AV/EDR scan across all endpoints

PHASE: RECOVERY [24–72 hours]

NIST Control: RC.RP-1 — Recovery plan is executed during or after a cybersecurity incident

TOOLS: Backup systems, SIEM monitoring, Email gateway

RESPONSE STEPS

- 1 Restore affected systems from clean backups if needed
- 2 Re-enable user accounts after credential reset is confirmed
- 3 Monitor affected accounts for 72 hours post-incident
- 4 Validate that all malicious artifacts are removed
- 5 Communicate resolution to affected users

PHASE: LESSONS LEARNED [Within 1 week]

NIST Control: RC.IM-1 — Recovery plans incorporate lessons learned

TOOLS: ITSM/ticketing system, Training platform, SIEM rule editor

RESPONSE STEPS

- 1 Conduct post-incident review with all stakeholders
- 2 Document timeline, root cause, and impact
- 3 Identify gaps in email filtering rules
- 4 Schedule phishing awareness training for affected users
- 5 Update detection rules based on observed indicators
- 6 File formal incident report (NIST SP 800-61 format)